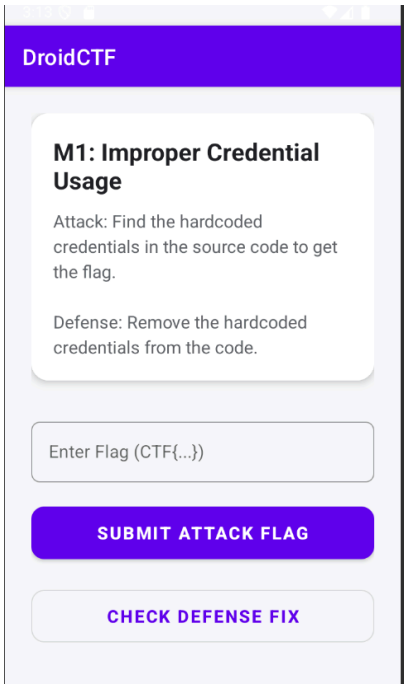
DroidCTF — Challenge & Hints
Mobile Security CTF | Package: com.droid.ctf

CHALLENGE 1 — Hardcoded Credentials
Category: Static Analysis | Points: 100
OWASP: M1 — Improper Credential Usage
Difficulty: Easy



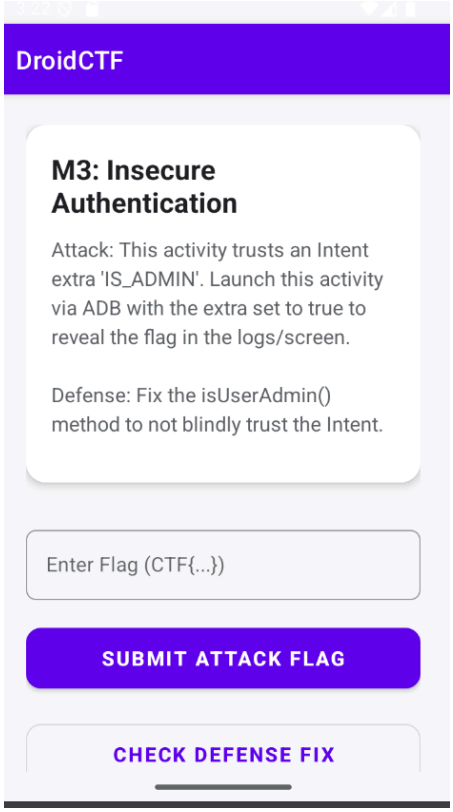
A developer left a password directly in the Kotlin source code.
Find it without ever running the app.

Objective:
  Decompile the APK and locate the hardcoded credential.
  Submit it as the flag.

Hint 1: You don't need to run the app. Decompile it.
Hint 2: Look at class-level field declarations in M1Activity.kt.

Defense Fix:
  Remove the hardcoded value. Store secrets in a secure backend
  or EncryptedSharedPreferences.

CHALLENGE 2 — Intent Spoofing
Category: Dynamic / ADB | Points: 100
OWASP: M3 — Insecure Authentication
Difficulty: Easy–Medium



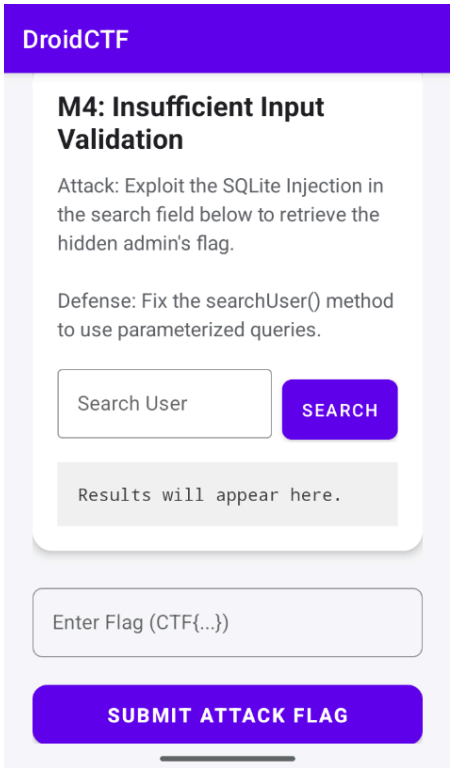
M3Activity grants admin access based on a boolean Intent extra.
Any external process can launch it with that extra set to true.

Objective:
  Launch M3Activity via ADB with a spoofed extra.
  Read the flag displayed on screen.

Hint 1: Check AndroidManifest.xml — is M3Activity exported?
Hint 2: Use adb shell am start with the --ez flag for booleans.

Defense Fix:
  Fix isUserAdmin() — never trust Intent extras for auth.
  Check a real session token instead, or return false.

CHALLENGE 3 — SQL Injection
Category: Input Validation | Points: 100
OWASP: M4 — Insufficient Input Validation
Difficulty: Medium



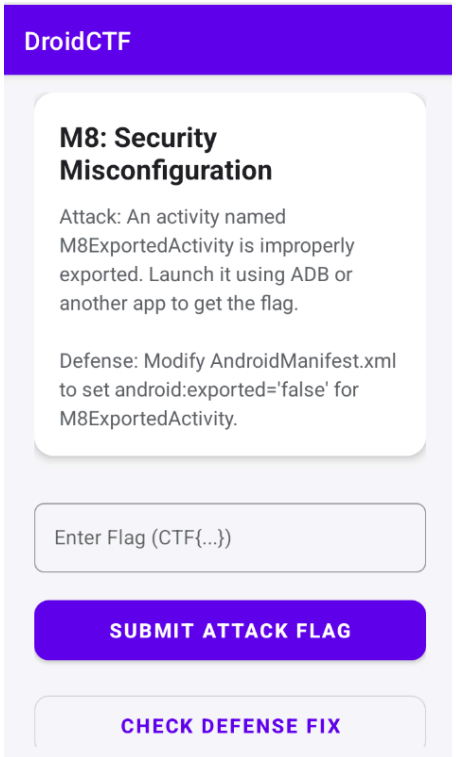
The M4 search field concatenates user input directly into a raw SQLite query. Craft a payload to dump all rows including a hidden admin record.

Objective:
  Use the in-app search field to inject SQL.
  Find the admin row — its secret is the flag.

Hint 1: The query is: SELECT * FROM users WHERE username = '<input>'
Hint 2: Make the WHERE clause always true using OR.

Defense Fix:
  Use parameterized queries.

CHALLENGE 4 — Exported Activity
Category: Misconfiguration / ADB | Points: 100
OWASP: M8 — Security Misconfiguration
Difficulty: Easy



M8ExportedActivity is marked exported="true" in the Manifest, so anyone can launch it directly — no authentication needed.

Objective:
  Launch M8ExportedActivity directly via ADB.
  The flag appears on screen immediately.

Hint 1: Decompile the APK and read AndroidManifest.xml.
      Which activity is exported when it shouldn't be?

Hint 2: adb shell am start -n com.droid.ctf/.<ActivityName>

Defense Fix:
  Set android:exported="false" for M8ExportedActivity
  in AndroidManifest.xml. Rebuild and reinstall.

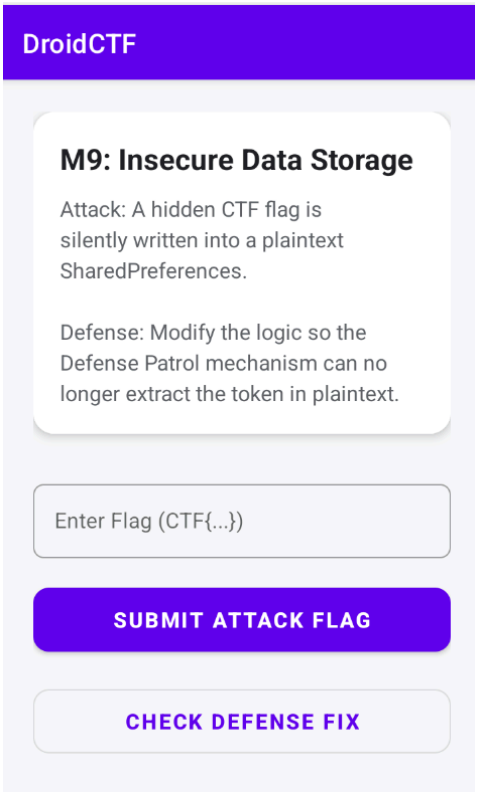
CHALLENGE 5 — Insecure Data Storage
Category: Storage / ADB | Points: 100
OWASP: M9 — Insecure Data Storage
Difficulty: Medium

M9Activity silently writes a secret token to SharedPreferences in plaintext. On debug builds, ADB can read these files directly.

Objective:
  Open the M9 screen to trigger the write, then read
  the SharedPreferences file via ADB to find the flag.

Hint 1: SharedPreferences live at:
  /data/data/com.droid.ctf/shared_prefs/
Hint 2: Use adb shell → run-as com.droid.ctf → cd shared_prefs && ls

Defense Fix:
  Remove local secret storage entirely, or replace with
  EncryptedSharedPreferences backed by Android Keystore.



BONUS — Admin Vault (Frida Hooking)
Category: Runtime Instrumentation | Points: Bonus
Difficulty: Hard

The Admin Vault is gated by isAdminUser() which always returns false. Use Frida to hook this method at runtime and return true.

Note: The app detects Frida via /proc/self/maps. You can attack OR verify the defense — not both at the same time.

Objective:

Hook isAdminUser() with Frida to return true.
Click the Admin Vault button to open the vault.

Hint 1: frida-server version must match your Frida client version exactly.
Hint 2: Push frida-server to the device:

```
adb push frida-server /data/local/tmp/
adb shell chmod 755 /data/local/tmp/frida-server
adb shell /data/local/tmp/frida-server &
```

APPLYING DEFENSE FIXES — IMPORTANT

Once you have applied all the code fixes (Kotlin source changes, Manifest changes, or both), the app must be rebuilt, recompiled, and reinstalled for the fixes to take effect. The Defense Patrol system validates the actual running binary — editing source alone is not enough.

Each passing defense check awards 100 points toward your Defense score. Complete all five to reach the maximum Defense total.

==========
Flag Format: CTF{...}
==========